

AD CS y certificados abusables

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

AD CS emite certificados para usuarios y equipos. Una plantilla mal configurada puede permitir a un usuario solicitar un certificado con identidad privilegiada y autenticarse como ella.

La CA confía en los atributos de la solicitud y en los permisos de la plantilla; combinaciones como enrollment abierto y sujeto controlable convierten una mala configuración en escalada de dominio.

Modelo mental

Entrada controlada -> transformaciones -> validación -> componente final
-> sink -> efecto observable -> decisión

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Cuando el dominio expone una CA y tienes una cuenta válida, especialmente si BloodHound o certipy muestran plantillas editables o enrolamiento amplio.

Cómo identificarla

- Certificate Templates
- ENROLLEE_SUPPLIES_SUBJECT
- Client Authentication
- ESC1
- CA web enrollment

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Enumera CAs y plantillas, identifica una plantilla vulnerable y solicita un certificado de prueba con una identidad permitida.

Evidencia esperada: Conoces la plantilla, los permisos que la hacen vulnerable y si el certificado permite autenticación como la identidad objetivo.

Construcción progresiva del payload

1. Reproduce una entrada válida.

2. Aísla un único valor controlable.
3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
certipy find -u '$USER@$DOMAIN' -p '$PASS' -dc-ip $DC_HOST -vulnerable
```

Objetivo y contexto: Enumera plantillas AD CS y marca configuraciones potencialmente vulnerables.

Resultado esperado: CA, plantilla, permisos y una razón concreta de vulnerabilidad.

Capa 2: prueba documentada

```
certipy req -u '$USER@$DOMAIN' -p '$PASS' -ca '$CA_NAME' -template '$TEMPLATE' -upn administrator@$DOMAIN -dc-ip $DC_HOST
```

Objetivo y contexto: Solicita un certificado de laboratorio solo cuando la plantilla y el alcance lo permiten.

Resultado esperado: Certificado .pfx emitido o un rechazo explicable.

Anatomía de los payloads

La primera prueba es `certipy find -u '$USER@$DOMAIN' -p '$PASS' -dc-ip $DC_HOST -vulnerable`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Conoces la plantilla, los permisos que la hacen vulnerable y si el certificado permite autenticación como la identidad objetivo.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Enumera CA y plantillas.
- Revisa permisos y EKUs.
- Solicita un certificado controlado y valida la autenticación.
- Documenta la causa raíz y revoca material de prueba.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- No hay CA AD CS publicada.
- La plantilla requiere aprobación manual y no tienes ese flujo autorizado.

- El alcance excluye pruebas de certificados.
- Ejecutar la prueba sin adaptar variables ni versión.
- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

Detectar plantillas de Active Directory Certificate Services que permiten suplantar identidades. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y preconditiones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.

4. Interpretar señal antes de escalar.

5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (ad-cs)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.